

# Other Attacks and Vulnerabilities

7BUIS022W

PortSwiger

Week 10

## Lab Objectives

- **You are expected to complete this lab before week 11**
- **Note this is formative and does not count towards your final mark but will help you to understand the labs and complete your assessment**
  1. Cross Site Scripting XSS
  2. Cross-site request forgery (CSRF)
  3. Server-side request forgery (SSRF)
  4. Path traversal
  5. File upload vulnerabilities
  6. Clickjacking attack
- Note: Not all labs in the PortSwigger academy are required. However you are encouraged to finish all labs.

## 1 Cross Site Scripting

- Visit Cross Site Scripting attacks
- You are expected in this section to complete the following:
  - Before starting the labs:
    - \* Read about Cross Site Scripting ☐
  - Complete the following labs:
    1. Lab: Reflected XSS into HTML context with nothing encoded ☐

2. Lab: Stored XSS into HTML context with nothing encoded ☐
3. Lab: DOM XSS in document.write sink using source location.search ☐
4. Lab: DOM XSS in innerHTML sink using source location.search ☐
5. Lab: DOM XSS in jQuery anchor href attribute sink using location.search source ☐
6. Lab: Reflected XSS into attribute with angle brackets HTML-encoded ☐
7. Lab: Stored XSS into anchor href attribute with double quotes HTML-encoded ☐

## 2 Cross-site request forgery (CSRF)

- Visit Cross-site request forgery (CSRF)
- You are expected in this section to complete the following:
  - Before starting the labs:
    - \* Read about Cross-site request forgery ☐
  - Complete the following labs:
    1. Lab: CSRF vulnerability with no defenses ☐
    2. Lab: CSRF where token validation depends on request method ☐
    3. Lab: CSRF where token is not tied to user session ☐
    4. Lab: CSRF where token is tied to non-session cookie ☐

## 3 Server-side request forgery (SSRF)

- Visit Server-side request forgery (SSRF)
- You are expected in this section to complete the following:
  - Before starting the labs:
    - \* Read about Server-side request forgery (SSRF) ☐
  - Complete the following labs:
    1. Lab: Basic SSRF against the local server ☐

## 4 Path traversal

- Visit Path traversal
- You are expected in this section to complete the following:
  - Before starting the labs:
    - \* Read about Path traversal ☐
  - Complete the following labs:
    1. Lab: File path traversal, simple case ☐
    2. Lab: File path traversal, traversal sequences blocked with absolute path bypass ☐

## 5 File upload vulnerabilities

- Visit File upload vulnerabilities
- You are expected in this section to complete the following:
  - Before starting the labs:
    - \* Read about File upload vulnerabilities ☐
  - Complete the following labs:
    1. Lab: Remote code execution via web shell upload ☐
    2. Lab: Web shell upload via Content-Type restriction bypass ☐
    3. Lab: Web shell upload via path traversal ☐

## 6 Clickjacking attack

- Visit Clickjacking attack
- You are expected in this section to complete the following:
  - Before starting the labs:
    - \* Read about Clickjacking attack ☐
  - Complete the following labs:
    1. Lab: Basic clickjacking with CSRF token protection ☐
    2. Lab: Clickjacking with form input data prefilled from a URL parameter ☐

## 7 Essential skills

- You are expected in this section to complete the following:
  - Complete the following lab:
    - \* Lab: Discovering vulnerabilities quickly with targeted scanning ☐

## 8 Business logic vulnerabilities

- Visit Business logic vulnerabilities
- You are expected in this section to complete the following:
  - Before starting the lab:
    - \* Read about Business logic vulnerabilities ☐
  - Complete the following lab:
    - 1. Lab: Excessive trust in client-side controls ☐
- Now you have completed the labs, in the class you will be looking to identify if those vulnerabilities exist on certain applications on OWASP. More information will be provided in the "In Class Lab document lab" in weeks 11/12.
- You are also expected to attempt to complete similar activities on your assignment scenario. Note, you will not succeed in all attempts.